# Assignment 15

## Differences Between Roles and Access

**Access** is a specific permission on a database object, such as the right to connect to a database or to read, add, change, or delete data in a table. **Roles** are named groups of permissions tied to a job function, such as "viewer" or "editor." Permissions are granted to the role, and users get those permissions by being assigned the role.

Granting access directly to each user means managing every user's permissions one at a time. With roles, an administrator sets permissions once and simply adds or removes users as their jobs change.

## Why Roles and Access Matter

Roles and access enforce the principle of least privilege, meaning each user gets only the permissions needed for their work (Richardson & Thies, 2013). This is important because it:

- Limits damage if an account is compromised or misused.
- Separates duties so no single user has full control.
- Makes adding, changing, and removing access faster and easier to audit.
- Helps meet compliance requirements for protecting sensitive data.

## Secure Role Setup (PostgreSQL)

### *Step 1: Create a Database*

sql

```sql
CREATE DATABASE school_db;
REVOKE ALL ON DATABASE school_db FROM PUBLIC;
```

### *Step 2: Connect to the Database*

bash

```bash
psql -U postgres -d school_db
```

sql

```
REVOKE CREATE ON SCHEMA public FROM PUBLIC;
CREATE TABLE students (id SERIAL PRIMARY KEY, name TEXT, grade INT);
```

***Step 3: Create Users***

sql

```
CREATE USER tom  WITH PASSWORD 'T0m!Secure22';
CREATE USER sara WITH PASSWORD 'S@ra!Secure22';
```

***Step 4: Create Roles***

sql

```
CREATE ROLE viewer NOLOGIN;
CREATE ROLE editor NOLOGIN;
```

***Step 5: Grant Permissions to Roles***

sql

```
GRANT CONNECT ON DATABASE school_db TO viewer, editor;
GRANT USAGE ON SCHEMA public TO viewer, editor;
GRANT SELECT ON students TO viewer;
GRANT SELECT, INSERT, UPDATE ON students TO editor;
GRANT USAGE ON SEQUENCE students_id_seq TO editor;
```

***Step 6: Assign Roles to Users***

sql

```
GRANT viewer TO tom;
GRANT editor TO sara;
```

Check assignments with `\du`. To remove access, use `REVOKE editor FROM sara;`.

## Conclusion

Access defines individual permissions, and roles group them by job function. Using least-privilege roles reduces risk and makes access easier to manage.

## Reference

Richardson, T., & Thies, C. N. (2013). *Secure software design*. Jones & Bartlett Learning.